

Mapeo normativo detallado de la Encuesta OCTAVE Nacional

Tabla de correspondencia entre cada bloque/pregunta de la encuesta y los principales marcos normativos y de referencia (ENS, NIS2, ISO 27001/27005, ISO 22301, RGPD, NIST CSF, OCTAVE).

1. Leyenda de marcos y referencias

- ENS: Esquema Nacional de Seguridad (RD 311/2022).[web:60][web:63][web:71]
- NIS2: Directiva (UE) 2022/2555 y normativa de desarrollo nacional.
- ISO 27001: ISO/IEC 27001:2022, Sistema de Gestión de Seguridad de la Información.
- ISO 27005: ISO/IEC 27005, Gestión de riesgos de seguridad de la información.
- ISO 22301: ISO 22301, Gestión de continuidad de negocio.
- RGPD: Reglamento (UE) 2016/679 y LOPDGDD.
- NIST CSF: NIST Cybersecurity Framework 2.0.[web:66]
- OCTAVE: Familia de métodos OCTAVE (clásico, Allegro, FORTE).

2. Tabla de mapeo (resumen por preguntas clave)

ID Pregunta	Dominio encuesta	Normativa / marco principal	Artículos / cláusulas relevantes	Justificación del mapeo
B.1 Estrategia de ciberseguridad	Gobernanza	ENS, ISO 27001, NIS2, OCTAVE FORTE	ENS art. 7, 10; ISO 27001 cl. 4, 5; NIS2 arts. 20–21	La existencia de una estrategia formal de ciberseguridad responde al principio de gestión basada en riesgos del ENS y al liderazgo y compromiso de ISO 27001; NIS2 exige políticas y procedimientos de gestión de riesgos y gobernanza; OCTAVE FORTE sitúa la estrategia de riesgo en el centro del programa.
B.2 Supervisión por el órgano de gobierno	Gobernanza	ENS, NIS2, ISO 27001, NIST CSF GOV	ENS art. 7; NIS2 art. 20; ISO 27001 cl. 5.1; NIST CSF “Govern”	La implicación del órgano de gobierno en la supervisión de la ciberseguridad es requisito de ENS y NIS2, que asignan responsabilidades a la dirección; ISO 27001 y NIST CSF insisten en el liderazgo y la gobernanza del riesgo.

B.3 Apetito de riesgo formalizado	Gobernanza / Riesgo	ENS, ISO 27005, OCTAVE FORTE	ENS art. 7, 28; ISO 27005 secc. 6–8; OCTAVE FORTE guía de apetito de riesgo	El establecimiento de umbrales y apetito de riesgo forma parte de la gestión de riesgos (ENS) y es central en OCTAVE FORTE; ISO 27005 explicita la necesidad de criterios de aceptación de riesgo.
B.4 Integración en ERM	Gobernanza / ERM	ISO 27001, ISO 27005, NIS2, OCTAVE FORTE	ISO 27001 cl. 4.1–4.2; ISO 27005; NIS2 arts. 20–21	La integración de ciberseguridad en ERM responde a la necesidad de alinear seguridad con contexto organizativo y partes interesadas, tal y como recogen ISO 27001/27005 y NIS2; OCTAVE FORTE busca precisamente esa integración.
C.1 Inventario de activos críticos	Activos	ENS, ISO 27001, ISO 27005, NIST CSF ID, OCTAVE Allegro	ENS Anexo II (medida de inventario de activos); ISO 27001 Anexo A.5.9; NIST CSF “Identify”; OCTAVE Allegro paso de perfilado de activos	El inventario de activos es requisito explícito del ENS y buenas prácticas ISO; OCTAVE Allegro se centra en la identificación y perfilado de activos de información y contenedores.

C.2 Cobertura del inventario	Activos	ENS, ISO 27001, NIST CSF ID	ENS art. 10, Anexo II; ISO 27001 Anexo A.5; NIST CSF ID.AM	La cobertura del inventario mide el grado de cumplimiento de los requisitos de identificación de activos que exigen ENS y NIST CSF.
C.3 Clasificación por impacto	Activos / Riesgo	ENS, ISO 27005, RGPD, OCTAVE Allegro	ENS art. 28, Guías CCN-STIC; ISO 27005 secc. sobre criterios de impacto; RGPD art. 32	La clasificación de activos según impacto está ligada a la gestión de riesgos (ENS, ISO 27005) y a la protección de datos personales según su sensibilidad (RGPD); OCTAVE Allegro define criterios de impacto sobre activos.
C.4 Identificación de contenedores	Activos / Riesgo	OCTAVE Allegro, ENS	OCTAVE Allegro pasos 2-3; ENS Anexo II medidas organizativas	OCTAVE Allegro introduce explícitamente el concepto de contenedores (personas, papel, sistemas, redes, terceros) como parte del análisis de riesgo.
D.1 Criterios formales de impacto	Riesgo	ENS, ISO 27005, OCTAVE Allegro	ENS art. 28; ISO 27005 secc. 6.3-6.5; OCTAVE Allegro paso 1	La definición de criterios de impacto es paso inicial en OCTAVE Allegro y requisito de ENS/ISO 27005 para el análisis de riesgos.

D.2 Dimensiones de impacto	Riesgo	ENS, ISO 27005, RGPD, ISO 22301	ENS principios básicos (seguridad, disponibilidad, integridad, confidencialidad); ISO 27005/22301; RGPD art. 32–34	Las dimensiones de impacto (continuidad, económico, reputación, cumplimiento, personas) reflejan los principios ENS y las exigencias de análisis de impacto de ISO/22301 y RGPD.
D.4 Uso de datos internos/externos para probabilidad	Riesgo	ENS, ISO 27005, ENISA, OCDE	ENS art. 28; ISO 27005; informes ENISA/OCDE	El uso de datos históricos y fuentes sectoriales se alinea con una gestión de riesgos informada por evidencias, como recomiendan ENISA y la OCDE en sus guías de medición.
D.5 Uso de OCTAVE y otras metodologías	Riesgo	ENS, ISO 27005, MAGERIT, OCTAVE	ENS remite a metodologías reconocidas (MAGERIT, ISO 27005); OCTAVE es una de las metodologías de referencia para análisis de riesgo de seguridad de la información.	
E.1 Gestión de vulnerabilidades	Operaciones	ENS, ISO 27001, NIST CSF PR.DS/PR.IP	ENS Anexo II (medidas de explotación); ISO 27001 Anexo A.8.8; NIST CSF PROTECT	Los procesos de gestión de vulnerabilidades y parcheo están explícitamente recogidos en ENS e ISO 27001 y en la función “Protect” de NIST CSF.

E.3 Monitorización de superficie de ataque	Operaciones	ENS, ISO 27001, NIST CSF DE, ENISA	ENS vigilancia continua; ISO 27001 Anexo A.5, A.8; NIST CSF DETECT	La monitorización de exposición externa y superficie de ataque responde al principio de vigilancia continua que recogen ENS y NIST CSF, así como las recomendaciones de ENISA.
E.4 Inteligencia de amenazas	Operaciones	NIST CSF DE, ENISA Threat Landscape	NIST CSF DE.CM; informes ENISA sobre threat intelligence	El uso de inteligencia de amenazas es recomendado por NIST CSF y ENISA como parte de la capacidad de detección y preparación ante incidentes.
F.1 Registro y clasificación de incidentes	Respuesta	ENS, NIS2, ISO 27035, NIST CSF RS	ENS art. 31–32; NIS2 art. 23–24; ISO 27035; NIST CSF “Respond”	El registro y clasificación de incidentes es requisito para la gestión de incidentes en ENS, NIS2 y los marcos ISO/NIST de respuesta.
F.2 Coordinación con CSIRTs / CERTs	Respuesta	ENS, NIS2	ENS protocolo de notificación; NIS2 art. 23–24	La coordinación con CSIRTs forma parte de las obligaciones de notificación y respuesta a incidentes bajo ENS y NIS2.

F.3 Planes de respuesta a incidentes	Respuesta	ENS, ISO 27035, ISO 22301, NIST CSF RS	ENS art. 10, 31; ISO 27035; ISO 22301; NIST CSF RS.RP	Los planes de respuesta a incidentes y su prueba periódica son requisitos en ENS e ISO; NIST CSF los recoge en la categoría Respond.
F.4 Integración en continuidad de negocio	Resiliencia	ENS, ISO 22301, NIS2	ENS principios de continuidad; ISO 22301; NIS2 requisitos de resiliencia	La integración de ciberseguridad en los planes de continuidad responde a la obligación de garantizar la prestación de servicios esencialmente continuos.
G.1-G.4 Capacidades y formación	Capacidades	ENS, ISO 27001, NIS2	ENS principios de seguridad integral y función formativa; ISO 27001 cl. 7; NIS2 art. 20	La dotación de recursos, competencias y programas de concienciación es exigencia de ENS, ISO 27001 y NIS2.
H.1 Alineamiento con ENS	Cumplimiento	ENS	RD 311/2022 completo	Pregunta directamente dirigida a medir el estado de adecuación al ENS.
H.2 Obligaciones NIS2	Cumplimiento	NIS2	NIS2 arts. 20-24	La pregunta evalúa el grado de preparación ante los requisitos de gestión de riesgos, medidas técnicas y de notificación.

H.3 Marcos internacionales	Cumplimiento / Buenas prácticas	ISO 27001, ISO 27005, ISO 22301, NIST CSF, OCTAVE	Normas ISO y NIST CSF; OCTAVE	Evalúa la adopción de marcos de referencia internacionalmente aceptados para la gestión de la seguridad y los riesgos.
H.4 Protección de datos personales	Cumplimiento	RGPD, ENS	RGPD arts. 24, 25, 32–34; ENS art. 4	El nivel de integración entre protección de datos y ciberseguridad se vincula a los principios de responsabilidad proactiva y seguridad del tratamiento.
I.1–I.5 Métricas, IGM y ROI	Métricas	ENS, ISO 27001, NIST CSF, OCDE, ENISA	ENS art. 10 (monitorización); ISO 27001 cl. 9; NIST CSF ID/ME; informes OCDE/ENISA sobre medición	El uso de indicadores, cuadros de mando e índices de madurez se alinea con los requisitos de monitorización y mejora continua; las métricas de ROI/ROSI siguen las recomendaciones recientes sobre medición de inversiones de ciberseguridad.

J.1-J.3 Percepción y prioridades	Estrategia	ENS, NIS2, OCTAVE FORTE	ENS art. 7; NIS2; OCTAVE FORTE 10 pasos	La autoevaluación global y la priorización de mejoras son coherentes con los ciclos de mejora continua y los programas de gestión de riesgos de OCTAVE FORTE y ENS.
---	------------	-------------------------	---	---

3. Uso recomendado del mapeo

- El mapeo permite trazar cada respuesta de la encuesta a un conjunto de exigencias normativas y buenas prácticas, facilitando la identificación de brechas de cumplimiento y de madurez.
- Puede utilizarse para elaborar informes de adecuación a ENS/NIS2/ISO basados en la autoevaluación, siempre subrayando que no sustituye a una auditoría formal.
- Sirve como base para priorizar acciones: por ejemplo, preguntas con puntuaciones bajas vinculadas a múltiples marcos (ENS, NIS2, ISO) señalan áreas de alto impacto regulatorio y de riesgo.

Este mapeo no pretende ser exhaustivo a nivel de artículo, pero ofrece una estructura suficientemente detallada para conectar la práctica cotidiana de la organización con el ecosistema normativo que, nos guste o no, marca buena parte de la partitura.